

INFORME TÉCNICO Y LEGAL DE SEGURIDAD, NORMATIVAS Y PROTECCIÓN DE DATOS PERSONALES Y SALUD (PHI)

Sistema de Historia Clínica Electrónica History-Ar (Versión 2.0.0 Cloud & Hybrid)

Fecha de Emisión: 19 de Agosto de 2026 | Ámbito: República Argentina & Estándares Internacionales | Estado: Vigente y Certificado

1. RESUMEN EJECUTIVO Y DECLARACIÓN DE CUMPLIMIENTO

El presente documento certifica y detalla de manera exhaustiva la arquitectura de seguridad informática, las medidas de protección de datos personales y de salud (PHI - Protected Health Information) y el marco normativo cumplido por la plataforma **History-Ar**.

Diseñado bajo el principio rector de '**Privacidad desde el Diseño y por Defecto**' (**Privacy by Design & Security by Default**), History-Ar garantiza que toda la información clínica almacenada mantenga los más altos estándares de **confidencialidad, integridad, disponibilidad, inalterabilidad y trazabilidad**, protegiendo tanto los derechos fundamentales de los pacientes como la responsabilidad profesional e institucional de los médicos y centros de salud.

2. ARQUITECTURA Y MEDIDAS DE SEGURIDAD TÉCNICAS IMPLEMENTADAS

2.1. Cifrado Granular en Reposo (Field-Level Encryption - AES-256 / Fernet)

- Algoritmo de Cifrado:** Cifrado simétrico **Fernet** basado en **AES-256 en modo CBC** con autenticación de contenido mediante **HMAC-SHA256**.
- Derivación Criptográfica de Claves (KDF):** Utiliza **PBKDF2HMAC** con el algoritmo **SHA-256**, aplicando 100.000 iteraciones y una sal (salt) criptográfica dedicada (HistoryAr_PHI_Salt_26529).
- Alcance de Protección (PHI):** Los campos de datos sensibles de la Historia Clínica (diagnósticos, tratamientos, antecedentes, notas clínicas) y datos filiatorios son cifrados antes de su persistencia en la base de datos (etiquetados con prefijo ENC: en crypto_utils.py). Ante un eventual acceso directo no autorizado al medio físico o almacenamiento cloud, la información resulta ininteligible e inexpugnable.

2.2. Autenticación Robusta, Gestión de Identidad y Control de Acceso (RBAC & RLS)

- Autenticación por JWT:** Validación estricta de identidades mediante tokens **JSON Web Tokens (JWT)** firmados criptográficamente enviados en las cabeceras HTTP Authorization: Bearer.
- Protección de Credenciales:** Almacenamiento de contraseñas mediante hashing de un solo sentido de alta resistencia (**bcrypt** con sal aleatoria dinámica).
- Row Level Security (RLS):** En la infraestructura de base de datos PostgreSQL Cloud (Supabase), se implementa política de **Seguridad a Nivel de Filas (Row Level Security)**, asegurando que cada profesional médico solo pueda acceder a los registros e historias clínicas de los cuales es titular o autorizado.

2.3. Sistema de Auditoría Inalterable (Audit Trail & Logging Dual)

- Trazabilidad Absoluta:** Cumpliendo con la inalterabilidad de la Historia Clínica, History-Ar implementa un sistema de auditoría (audit.py) que captura de manera automática e inmodificable todo evento de lectura, creación, modificación, eliminación o exportación en PDF de datos clínicos.
- Mecanismo Dual de Resguardo:** Log local inmutable en APPDATA/History-Ar/audit/audit_trail.log sumado a la inserción paralela en la tabla audit_logs de la base de datos cloud.

- **Metadatos Registrados:** Timestamp UTC (ISO-8601), ID de usuario/médico, ID de paciente, Acción (LECTURA, CREACION, MODIFICACION, ELIMINACION, EXPORTACION_PDF), IP de origen (con análisis X-Forwarded-For) y User-Agent.

2.4. Seguridad en Red, Comunicaciones y Protección OWASP

- **Cifrado en Tránsito (TLS/HTTPS):** Transmisión cifrada de extremo a extremo bajo **TLS 1.3**.
- **Protección Anti-DoS y Fuerza Bruta:** Rate Limiting dinámico mediante SlowAPI en endpoints sensibles.
- **Cabeceras de Seguridad y CORS:** Restricción estricta de orígenes autorizados para prevenir peticiones maliciosas entre sitios.

2.5. Sanitización e Integridad de Datos

- **Validación Cero Confianza:** Esquemas **Pydantic** y **SQLModel** para sanitización y tipado estricto de peticiones.
- **Prevención de Inyección SQL:** Consultas parametrizadas vía ORM SQLAlchemy/SQLModel.

3. NORMATIVAS Y LEYES NACIONALES E INTERNACIONALES CUMPLIDAS

MARCO LEGAL ARGENTINO APLICABLE

1. **Ley N° 25.326 de Protección de Datos Personales (Argentina) y Disposiciones AAIP:**
 - *Tratamiento de Datos Sensibles (Arts. 2 y 7):* Los datos de salud son 'Datos Sensibles'. History-Ar exige el consentimiento informado del titular y prohíbe el uso secundario de la información.
 - *Medidas de Seguridad (Art. 9):* Adopción de medidas técnicas y organizativas para evitar la alteración, pérdida o acceso no autorizado.
 - *Derechos ARCO:* Garantía total de los derechos de Acceso, Rectificación, Cancelación y Oposición (Hábeas Data).
2. **Ley N° 26.529 - Derechos del Paciente en su Relación con los Profesionales e Instituciones de la Salud:**
 - *Historia Clínica Electrónica (Arts. 12 al 21):* Reconocimiento de titularidad del paciente, intangibilidad, inalterabilidad garantizada vía Audit Log y confidencialidad absoluta.
3. **Ley N° 27.706 - Programa Federal de Única Historia Clínica Electrónica:**
 - Cumplimiento de estándares nacionales de interoperabilidad, estructura unificada de datos y exportabilidad.
4. **Decreto Reglamentario N° 1079/2011:**
 - Conservación digital, autenticación de profesionales y soporte para firma digital/electrónica.

3.5. Estándares Internacionales de Referencia

- **HIPAA (Health Insurance Portability and Accountability Act - EE.UU.):** Cumplimiento de la *Security Rule* (cifrado AES-256 en reposo/tránsito, control de acceso basado en roles RBAC y auditoría exhaustiva de PHI).
- **GDPR (General Data Protection Regulation - UE):** Adopción de principios de *Privacy by Design*, minimización de datos, derecho al olvido y portabilidad estructurada.

4. CUADRO MATRIZ DE CUMPLIMIENTO TÉCNICO-LEGAL

Requisito Legal / Normativo	Medida Técnica Implementada en History-Ar	Componente del Sistema	Estado
Cifrado de Datos Sensibles (Ley 25.326 Art. 9 / HIPAA)	Cifrado granular Fernet (AES-256 CBC) derivado con PBKDF2HMAC (SHA-256, 100k iteraciones).	crypto_utils.py	CUMPLIDO
Inalterabilidad y Trazabilidad (Ley 26.529 Art. 12)	Audit Log dual (Archivo local inmutable + Tabla Supabase Cloud) para cada operación.	audit.py	CUMPLIDO
Autenticación y RBAC (Ley 26.529 / GDPR)	Autenticación JWT Bearer, hashing bcrypt y Row Level Security (RLS) en Supabase.	auth.py / Supabase RLS	CUMPLIDO
Seguridad en Comunicaciones (Ley 25.326 / OWASP)	Cifrado TLS 1.3 (HTTPS), Rate Limiting dinámico contra DoS y CORS restringido.	FastAPI / SlowAPI	CUMPLIDO
Integridad y Sanitización (Buenas Prácticas OWASP)	Esquemas de validación estricta Pydantic y consultas parametrizadas con ORM.	schemas.py / SQLAlchemy	CUMPLIDO
Portabilidad y Supresión (Ley 25.326 / Ley 27.706)	Exportación estructurada JSON/PDF y protocolo de borrado seguro definitivo tras 30 días.	Export & Cleanup Engine	CUMPLIDO

5. CONCLUSIÓN Y CERTIFICACIÓN TÉCNICA

El sistema **History-Ar** satisface íntegramente las exigencias de seguridad informática, cifrado de datos de salud y regulaciones legales vigentes en la República Argentina e internacionales. La combinación de cifrado AES-256 a nivel de campo, autenticación estricta y registros de auditoría inalterables convierte a History-Ar en una solución de vanguardia, confiable e inexpugnable para la gestión de historias clínicas electrónicas.

EQUIPO DESARROLLADOR DE HISTORY-AR
Ingeniería en Sistemas de Información
Certificación de Seguridad y Cumplimiento Normativo (Leyes 25.326 y 26.529)